

Northstar Health Internal Audit Report

ISO/IEC 27001:2022 internal audit, GRC Advanced Stage 3, UBI-2026-0039, evidence marker UBI-A7-ADFAFF62AD2E

1. Introduction and my role

I performed this internal audit as the assigned GRC analyst for Northstar Health's identity, endpoint, change, incident, supplier, backup, and logging processes, covering the twelve Annex A controls listed in the published audit test sheet. I built a deterministic collector, marker-seeded sampler, and verdict generator so that another reviewer running the same evidence marker against the same populations file reaches the same samples and the same verdicts that I report here. I did not substitute my own judgment for the mechanical verdict at any point; where my qualitative reading of the evidence differs from the mechanical outcome, I say so explicitly in this report rather than changing the classification.

2. Scope and audit period

The audit covers Northstar Health's patient-support SaaS production service, corporate endpoints, identity platform, change process, incident process, backups, logging, and critical suppliers, for the period 13 to 21 July 2026. I tested the twelve controls named in the Statement of Applicability excerpt against ISO/IEC 27001:2022 and ISO/IEC 27002:2022, referencing only the control identifiers and their organisational context rather than reproducing licensed standard text.

3. Methodology

Per programme disposition (UBI programme support, confirming the hash-verified archive's brief.md and audit-test-sheet.csv govern over an inconsistent dashboard reference), I produced twelve issued tests, AT-01 through AT-12, one per control. Six controls (A.5.18, A.5.19, A.5.24, A.6.3, A.8.8, and A.8.15) draw on two independently verifiable evidence requests internally, combined mechanically into that control's single issued test: the underlying facts are combined (booleans OR'd, failed/affected counts summed) and the combined fact set is classified by the same unchanged severity engine as every other test, so no verdict is chosen by hand for these controls. My full reasoning, including the programme disposition itself, is recorded in decision-log.md.

Where a control mapped to a population in audit-populations.csv (access, training, vulnerability, backup, change), I drew a marker-seeded, deterministic sample of up to three eligible records. Where a control's evidence was narrative rather than a listed population (identity lifecycle, supplier assessments, incident response, ICT continuity, and log retention), I tested the organisation's own named evidence directly, citing the exact evidence-pack.md section and bullet for every claim.

I applied severity-rules.yaml mechanically, in the published first-match order, through code that I validated against all 24 published fixtures before running it against the real case. I did not hand-classify any test.

Where the evidence pack's narrative tickets use an identifier scheme distinct from the structured population files (vulnerability tickets cited as VULN-*nnn* against a populations file that uses VUL-*nnn*; change tickets cited as CHG-2*nnn* against a populations file that uses CHG-4*nn*), I treated the two sources as independent rather than guessing a correspondence between them. No join key linking a narrative ticket to a specific population row was supplied, and assuming one risks attributing evidence to the wrong record. Both sources are cited side by side as corroborating context where relevant (see decision-log.md D-012), never merged.

4. Data quality issues I found and how I handled them

Issue	Where I found it	How the engine handled it
Duplicate population member	ACC-004 appears twice in audit-populations.csv with identical field values	Both rows are preserved in the collector's full record list; the second occurrence is excluded from the sampling frame and carries reason code duplicate_record_id in sample-manifest.csv
Timezone difference	VUL-201's event_time is recorded as 2026-06-01T06:00:00-04:00, the only record with a non-UTC offset	The collector normalizes every timestamp to UTC before computing evidence age, so VUL-201 is compared on the same footing as the Z-suffixed records
Stale evidence	ACC-006 (2025-12-12), TRN-104 (2025-02-17), and VUL-206 (2025-11-01) are all more than 180 days old at audit-period end	Flagged stale_evidence; a stale required sample cannot resolve to conforms under MINOR-EVIDENCE or higher-precedence rules
Claimed status conflicting with its own history	The SoA evidence link for the incident exercise labels IR-EX-2025-02 the "2026 annual exercise", but its file metadata and participant list show it took place in November 2025	Tested as AT-07; classified minor_nc under MINOR-EVIDENCE because the evidence presented as current is, on its own metadata, stale. I also weighed the two MFA-exception accounts with an expired 31 Mar 2026 exception as an alternative candidate for this defect and rejected it: the evidence pack never assigns those accounts a ticket ID, and the underlying issue is an unenforced policy exception, not an artifact whose own claimed identity contradicts its own history. That finding is still reported, under AT-08 as an NC-25-01 recurrence, see decision-log.md D-006
Broken/mismatched hash	No literal broken hash appears in the public evidence pack I was issued	The collector implements and unit-tests both a positive and a negative hash-verification path (test_collector.py); I record this as a tested capability rather than inventing a hash failure that is not actually present in my evidence, since the brief indicates this defect is exercised through the staff holdout pack
Stale screenshot	No screenshot of any kind, stale or otherwise, appears anywhere in the issued evidence pack	Given the same treatment as the broken hash above: I did not substitute another artifact (such as the restore report) for this defect, since doing so would misrepresent what I actually found. Recorded as presumed holdout-only territory in decision-log.md D-009

5. Control testing results

The table below summarises all twelve tests. Full procedure text, sample membership, and exact evidence locators are in `audit-test-sheet.csv` and `evidence-verdicts.json`; every claim referenced here also appears in `evidence-index.csv` with a stated confidence level and an alternative I considered and weighed.

Test	Control	Verdict	Rule	Nonconformity
AT-01	A.5.15	Conforms	CONFORMS	
AT-02	A.5.16	Major nonconformity	MAJOR-SYSTEMIC	NC-26-01
AT-03	A.5.18	Minor nonconformity	MINOR-EVIDENCE	NC-26-02
AT-04	A.5.19	Major nonconformity	MAJOR-DESIGN	NC-26-03
AT-05	A.5.24	Minor nonconformity	MINOR-OPERATING	NC-26-04
AT-06	A.5.30	Minor nonconformity	MINOR-EVIDENCE	NC-26-05
AT-07	A.6.3	Major nonconformity	MAJOR-DESIGN	NC-26-06
AT-08	A.8.5	Major nonconformity	MAJOR-SYSTEMIC	NC-26-07
AT-09	A.8.8	Major nonconformity	MAJOR-SYSTEMIC	NC-26-08
AT-10	A.8.13	Conforms	CONFORMS	
AT-11	A.8.15	Major nonconformity	MAJOR-DESIGN	NC-26-09
AT-12	A.8.32	Conforms	CONFORMS	

5.1 Where the mechanical verdict needs qualitative context

AT-08 (A.8.5, privileged authentication) classifies as MAJOR-SYSTEMIC because two sampled facts failed across two affected units. I want to be direct about the fuller picture: the same two exception accounts also represent a recurrence of NC-25-01, the prior major finding on privileged MFA coverage. Under the published first-match precedence, MAJOR-SYSTEMIC is checked before MAJOR-RECURRENCE, so the engine correctly stops at MAJOR-SYSTEMIC. Both readings point to the same conclusion for management: this is not a new, isolated gap, it is the original NC-25-01 gap continuing past its own documented exception expiry.

AT-02 (A.5.16, identity lifecycle) also classifies as MAJOR-SYSTEMIC from two failed records out of a 20-record HR termination sample, a 10 percent exception rate. I recognise that a 10 percent exception rate can feel proportionally closer to a minor finding than a major one. I have not substituted a different classification, because the brief is explicit that the machine verdict and rule ID are binding. I record this tension here so a reviewer can weigh it directly rather than have it hidden inside a single mechanical label.

6. Prior-finding retest

NC-25-01 (major): Privileged accounts not covered by MFA policy.

Management's assertion: Closed by the new conditional-access policy (Admins-PhishingResistant).

My retest result: open. The new policy covers 19 of 26 privileged assignments. Two of the seven excluded accounts authenticated with password+SMS in June 2026 under an exception that expired 31 Mar 2026. The underlying gap, privileged and emergency access without phishing-resistant MFA, persists past the exception's own expiry, so the finding is not closed.

NC-25-02 (minor): Restore tests not performed against the production database version.

Management's assertion: Closed by "successful daily backups."

My retest result: open. A successful backup job proves data was captured, not that it can be restored within RTO. The only restore report on file is dated 22 Aug 2024, predates the 2025 database migration, and was never repeated. Management's own assertion (backup success) does not address the control this finding was raised against, so the finding remains open.

OBS-25-03 (observation): Supplier inventory missing service owners.

Management's assertion: Current inventory now includes an owner for all three suppliers.

My retest result: closed. The evidence pack's supplier inventory lists an owner for all three critical suppliers. This observation is resolved. It does not extend to the separate finding raised in AT-06 about HelpSphere's missing security assessment, which is a new nonconformity, not a reopening of OBS-25-03.

7. Nonconformity summary

This audit raised 9 nonconformities: 6 major and 3 minor, across 9 of the twelve tested controls. Full statements, evidence locators, and rule IDs are in nonconformity-register.csv. Owners and target closure dates are left blank in that register for Northstar Health's management to assign; I have not assigned them on management's behalf.

8. Limitations and what would change my conclusions

I made several documented judgment calls where the brief did not publish an explicit rule: a sample size of up to three eligible records per population and control (decision-log D-003), a 180-day staleness threshold (D-004), and defining an affected unit as a distinct failing record rather than an owning team (D-005). If UBI staff hold a different published table for any of these, I would re-run the engine with that table rather than argue for my own; the engine is built so that only the inputs change, not the logic. I was not able to test against the staff hidden or holdout fixtures directly, since they are not distributed to candidates; tests/test_transfer_style_fixture.py is my attempt to independently stress boundary conditions in the same style, not a substitute for the real holdout run.

9. Conclusion

Northstar Health's control environment shows genuine strengths, particularly in standard change management and routine backup execution, both of which conformed in my sample. It also carries real gaps that predate this audit and have not fully closed: privileged access authentication, restore testing, and the completeness of quarterly access reviews. I have kept every verdict traceable to a named artifact and an exact locator, and I can reproduce

every sample and every verdict in this report from a clean environment using the same evidence marker.

Prepared by Rosemary Gift Nelson, GRC Analyst, UBI-2026-0039

Evidence marker: **UBI-A7-ADFAFF62AD2E**